

Full Duplex Authentication®

Mitigating Phishing, Browser-in-Browser, and Rogue Proxy Attacks

This white paper explores Full Duplex Authentication®, a cutting-edge security technology designed to address the escalating threats of phishing, browser-in-browser and rogue proxy attacks. To lay the foundation for understanding Full Duplex Authentication®, we will first explore the nature of these cyber threats and then detail the innovative approach of [U.S. Patent 11,245,526](#).

Introduction

Online security is paramount as cyber threats evolve in today's digital landscape. Phishing, browser-in-browser and rogue proxy attacks have replaced sophisticated methods by which malicious actors attempt to compromise user credentials and sensitive information. Full Duplex Authentication® is proving to be a robust solution to counter these threats.

What is Authentication?

Authentication is the process of verifying an online digital identity. When a person is associated with a digital identity, they are asked to provide credentials that they are who they assert themselves to be.

Three standard methods of validation:

- The first method is something a user knows, such as a password, a personal identification number (PIN), or a one-time passcode (OTP).



- The second method is something a user normally has, e.g. a registered device, a digital token on that device or a specific hardware device such as a Yubikey.
- The third method is something that is a user, namely a biometric feature such as facial recognition or fingerprint. If a user performs more than one action for verification, this is known as multi-factor authentication (MFA). To ensure the highest level of security when authenticating a digital identity, all three validation methods should be performed each time a user authenticates to a system or service.

Understanding Cyber Threats to Authentication

Social engineering and phishing attacks account for **70% to 90%** of all malicious security breaches.

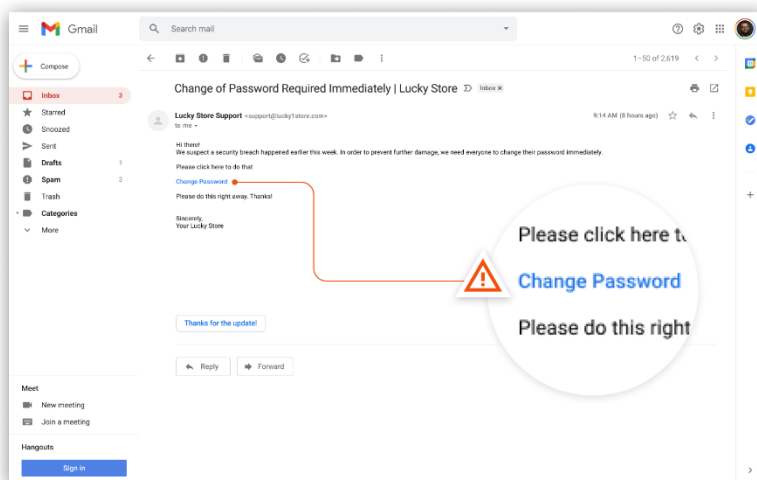
Source: KnowB4

For several years, bad actors have focused their cyberattacks on stealing online login credentials.

According to [the Verizon DBIR](#), in 2023, 74% of security breaches involved the human element, including social engineering attacks such as phishing.

It has become easier for bad actors to obtain a user's credentials using various social engineering techniques than to conduct sophisticated brute force attacks.

Here are some of the more common methods used by bad actors to fraudulently obtain user credentials and bypass multi-factor authentication:



- **Phishing Attacks:** Phishing involves fraudulent attempts to obtain sensitive information by disguising it as a trustworthy entity. Phishing is usually spread via fraudulent emails or websites and exploits human psychology to trick users into revealing confidential data. Variations of phishing include smishing, which uses text messages, and Vishing, which hacks password

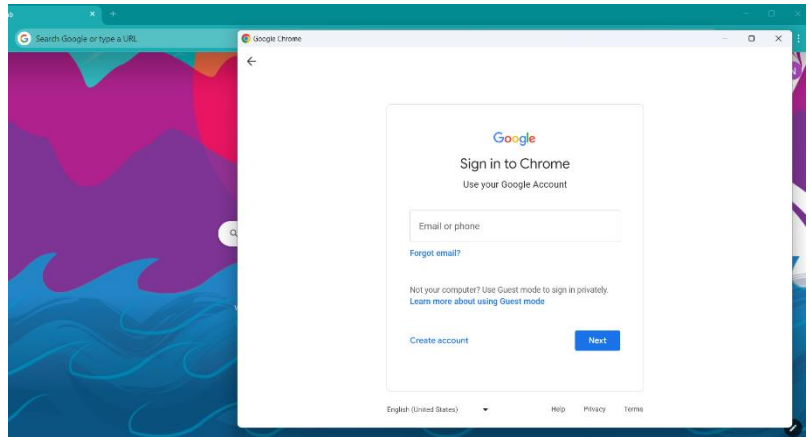
resets sent via voice mail. Quishing uses QR codes to guide users through the trap. Phishing is often used in conjunction with impersonating emails and websites.

The user receives a fake email that appears to come from a legitimate organization such

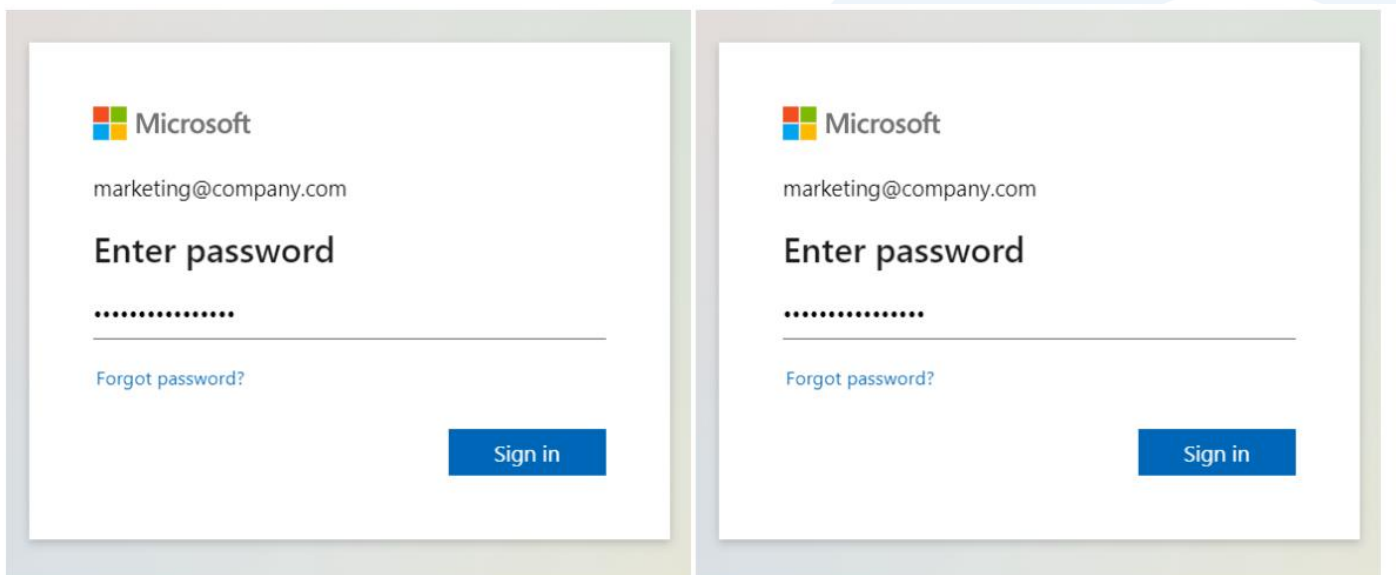
as a bank, telecommunications company or even a tech giant like Amazon, Microsoft, Apple or Google. The email will indicate a problem with the account and asks the user to log in. When the user clicks on the hyperlink, they often miss the URL, which is different from the website they think they are going to. Once the user enters their login credentials, their account has been compromised.

- **Browser-in-Browser Attacks:** Browser-in-browser attacks occur when a malicious entity injects code into a legitimate website, compromising the security of the user's browser.

This allows attackers to steal sensitive information or execute unauthorized actions on behalf of the user. This type of attack is difficult for the user to detect. The user may not notice the URL change because no URL is displayed in browser-in-browser dialogs. Once the user enters their credentials, their account has been compromised.



- **Rogue Proxy Attacks:** Rogue proxy attacks involve the interception of communication between the user and a web server using malicious proxy servers. Attackers can intercept sensitive data, maliciously manipulate the communication and steal the password when logging in.



Can you spot what is fake?

About Full Duplex Authentication®

Even if the world stopped using knowledge-based verification methods, it would not prevent the types of phishing and social engineering attacks that occur today. This is because all authentication methods used today have a fundamental flaw: The verification flow is one-way. The requesting authentication service will challenge the user to perform the necessary actions to prove their validity.

The user must be able to challenge the requesting authenticating service to prove its validity. This allows all the bad actors to impersonate a legitimate service to trick the user into providing the password, digital token or biometric verification of the device.

Identité® developed and patented Full Duplex Authentication® to address this fundamental flaw in authentication. The concept of Full Duplex Authentication® is encapsulated in [U.S. Patent 11,245,526](#). This patent introduces a novel authentication method that involves bi-directional and encrypted communication between the user and the authentication system. In contrast to conventional one-way authentication, Full Duplex Authentication® ensures a continuous and dynamic exchange of information throughout the entire authentication flow.

How does Full Duplex Authentication® work?

An authentication server, which Identité calls NoPass™, short for "no password", creates a



secure relationship with a third-party service. Third-party services collect user identification and begin the initial authentication process. These services include Microsoft AD and Azure, SSO tools such as Okta, VPN, Citrix or any application or portal that requires a user to authenticate. A NoPass™ server has several ways to integrate with third-party services.

- **Federated SSO** – NoPass™ server is configured to act as an identity provider for services such as Microsoft Azure/AD or other SSO authentication tools such as Okta, PingIdentity, KeyCloak, etc.
- **RADIUS** – NoPass™ server is configured to act

as a RADIUS client

- **API** – NoPass™ server is configured to establish secure communication with web portals and mobile applications

The NoPass™ server interacts with a user via applications running on iOS, Android, Windows and MacOS. These are obtained via the public app stores, usually when a user registers for NoPass™ authentication for the first time. The app receives secure push notifications from the NoPass™ server whenever a user requests authentication to a third-party server configured to use NoPass™ Full Duplex Authentication®. The app contains a unique set of credentials for each web portal or service that the user has registered. These credentials are encrypted but cannot be used to gain access to a service, e.g. in the case of a replay attack. Users can back up their credentials and sync them to other devices if the security policy allows.

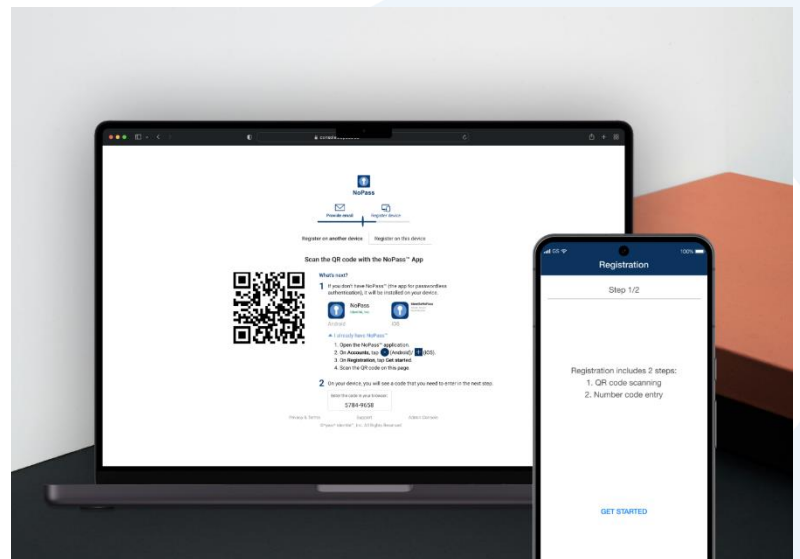
Full Duplex Authentication® Registration Flow

To register for Full Duplex Authentication®, users must authenticate themselves using the service's native authentication flow. This is typically done by providing a username and password. Once the service verifies authentication, the user is redirected to a registration interface for Full Duplex Authentication®. Registration will involve the user and a device such as a PC, Mac or smartphone.

Depending on the security policy set in the NoPass™ Authentication Server, the user selects the device and installs a small application. The application has the task of storing a Full Duplex Authentication® credential for each user account on each service for which the user registers. Multiple user accounts are supported for the same service.

The Full Duplex Authentication registration interface allows the user to scan a QR code or tap or click on a "Continue" button, which invokes a local installation of the Full Duplex Authentication® app.

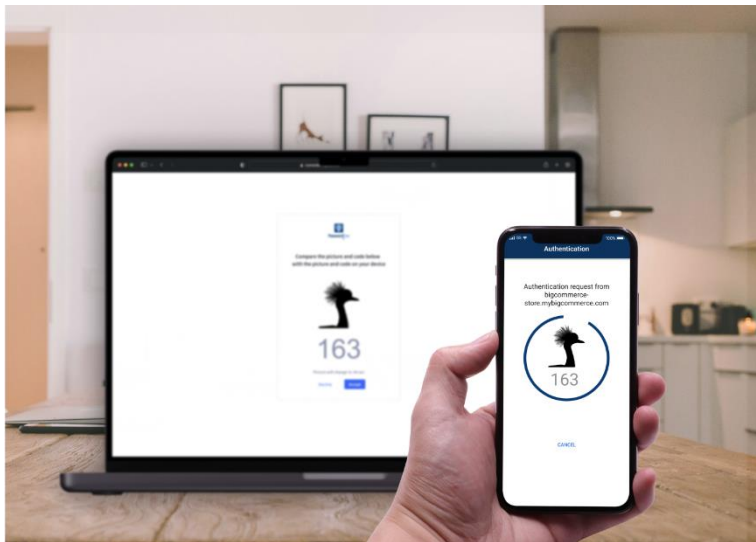
Suppose the user installs the authentication app on a device other than the one displaying the registration interface. In this case, the user will be asked to confirm an 8-digit code to ensure that they are in possession of the secondary device. Once the registration confirmation is confirmed, the user is authenticated and returns to the service to continue their task without further interruption. When the user logs out and returns to the service, they are not prompted for a password. Instead, they are guided through the Full Duplex Authentication® flow.



When the Full Duplex Authentication® app is installed on a device, it recognizes and utilizes additional authentication factors if available. These can include biometrics and hardware tokens such as a Yubikey. The Full Duplex Authentication® app can also be configured to use a PIN. These additional factors mitigate risks if the device is lost or stolen.

The Full Duplex Authentication® Usage Flow

Users have the option of choosing between a single device and two devices. Dual devices are more secure as they require one device to display the login dialog and a second authentication device with an authenticator app to receive and accept the push notification. In the case of a dual device, a user will initiate the login process by entering a username on the first device. The username is sent to the NoPass server. When the username has been registered, the NoPass server sends authentication instructions to the registered portal. When the user enters the username, a picture and a number appear on the registered authentication device.



Full Duplex Authentication® is complete when the app on the registered device authenticates the authenticating server and accepts the message payload to display the picture and number. When the app accepts the server's credentials on the user's device, the app decrypts and builds the same picture and number on the authentication device. These pictures and numbers change every 30 seconds, so Full Duplex Authentication® will repeat until the user responds to the prompt on their authentication device. The settings

on the NoPass server can limit login attempts to prevent the user from accidentally accepting the push notification (push fatigue). The user can also decline if they have not initiated the login attempt.

Before returning the confirmation that the user credentials are valid to the NoPass server, additional authentication factors can be executed. This may include verifying the presence of a HW token such as a Yubikey or a biometric token. The options supported depend primarily on the device and the available options. For example, iPhones and Android devices have built-in biometric features such as facial recognition and fingerprints.

Another example might be that a Yubikey is required to secure a virtual machine or shared workstation. After the local security check has been performed, the authentication app sends

the credentials back to the NoPass server. If they are valid, the NoPass server tells the third-party server or web portal to let the user into the application.

Full Duplex Authentication® Prevents Common Cyber Attacks

Most cyber-attacks involve stealing a user's credentials. Organizations have made significant progress in developing and implementing tools that prevent bad actors from using sophisticated malware and known vulnerabilities to breach an organization. As a result, bad actors have turned to less sophisticated tools and methods, targeting the weakest link in security – the human.

Full Duplex Authentication® provides extra protection against socially engineered attacks because the requesting authentication service must always authenticate itself to the user. Here are some types of cyberattacks and how Full Duplex Authentication® thwarts them.

- **Phishing Prevention:** Full Duplex Authentication® introduces dynamic challenges and responses throughout the authentication process. The required real-time interaction between the user and the Full Duplex Authentication® server mitigates the effectiveness of phishing attacks, as static credentials (passwords, tokens, etc.) alone are not sufficient for successful authentication.
- **Browser-in-Browser Attack Mitigation:** Full Duplex Authentication®'s bi-directional communication enables constant verification of the legitimacy of the user's browser. Any unauthorized code injection or manipulation attempts are detected promptly, preventing browser-in-browser attacks.
- **Rogue Proxy Attack Resilience:** Full Duplex Authentication® consistently verifies the authenticity and origin of the communication channel. This resilience disrupts the tactics employed in rogue proxy attacks and prevents unauthorized interception and manipulation of data.

Business Impact

As noted in [the Verizon DBIR for 2023](#), the majority of data breaches are committed via humans. This is because humans are the weakest link in the security chain.

In addition to the potential loss from unauthorized access, there are operational costs associated with password- and



In 2023, the
average cost of a
data breach was
\$4.5 million.

Source: Ponemon Institute

hardware-dependent multi-factor authentication. Due to the risks associated with using passwords, they need to be changed regularly, with best practice suggesting a change every 90 days. This can cost an organization up to one employee man-hour for every password every year.

If hardware MFA devices are lost or defective, the cost of replacing each device adds to the operational costs. Full Duplex Authentication® apps can be deployed on a device that the employee already owns. This app performs at least two factors of authentication, significantly reducing the operational costs associated with other MFA tools.

Bottom Line

As cyber threats evolve, innovative security measures are essential. Full Duplex Authentication®, as described in [U.S. Patent 11,245,526](#), stands at the forefront of modern authentication solutions, providing a dynamic and robust defense against phishing, browser-in-browser and rogue proxy attacks.

The implementation of this innovative and award-winning technology is critical to protecting the integrity and confidentiality of online interactions in an ever-changing digital landscape.

Full Duplex Authentication® enables the elimination of passwords in the authentication flow. This not only simplifies the authentication flow, but also reduces the operational costs associated with password management.

[Visit the Idemite website](#) to learn more about our MFA solutions.

Connect with us on [LinkedIn](#) for getting news in the security and identity management domains.

[Click here](#) to contact our Sales department and request demos.